



Requirement 9: Restrict Physical Access to Cardholder Data

ENHANCING SECURITY MEASURES TO PREVENT UNAUTHORIZED ENTRY TO SENSITIVE PAYMENT INFORMATION





The Importance of Physical Access Controls

Restricting physical access is vital for protecting payment data

- Prevents breaches from simple unauthorized entry

Digital defenses alone are not sufficient for security

- Physical controls protect the "digital treasure"

Only legitimate personnel should access cardholder data

- Supports trust and business continuity

Physical controls are foundational to organizational resilience

- Essential for both compliance and assurance

Defining Physical Access Controls

Physical access controls limit entry to sensitive cardholder data areas

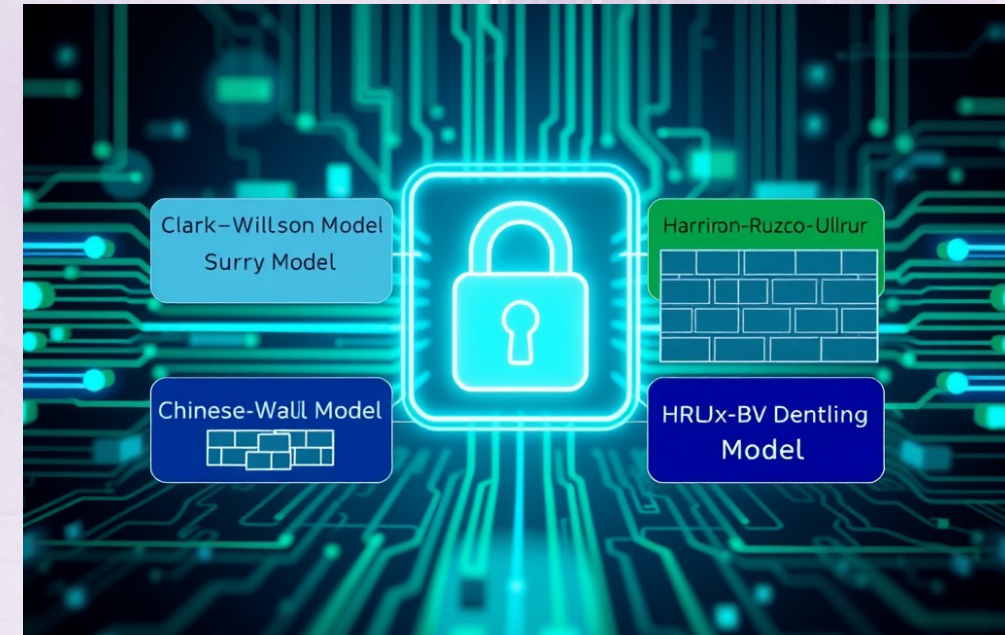
- Mechanisms, policies, and procedures are all included

Controls range from locks to multi-factor authentication systems

- Can include badges, biometrics, and surveillance

Principle of least privilege is central to access control

- Only required roles receive access to cardholder data



Physical Zones and Security Layers

Organizations mirror museums with public and highly secure zones

- Only select staff access high-security areas

Access is documented, tracked, and periodically reviewed

- Ensures ongoing verification and control

Facilities processing cardholder data define security zones

- Public, restricted, and secure areas have increased protection levels

Each zone must have escalating layers of physical security

- Barriers increase with sensitivity of data



Designing Facility Access Controls

Map facility floor plans to identify risk points

- Entryways, rooms, and closets need scrutiny

Implement technology like badge and biometric systems

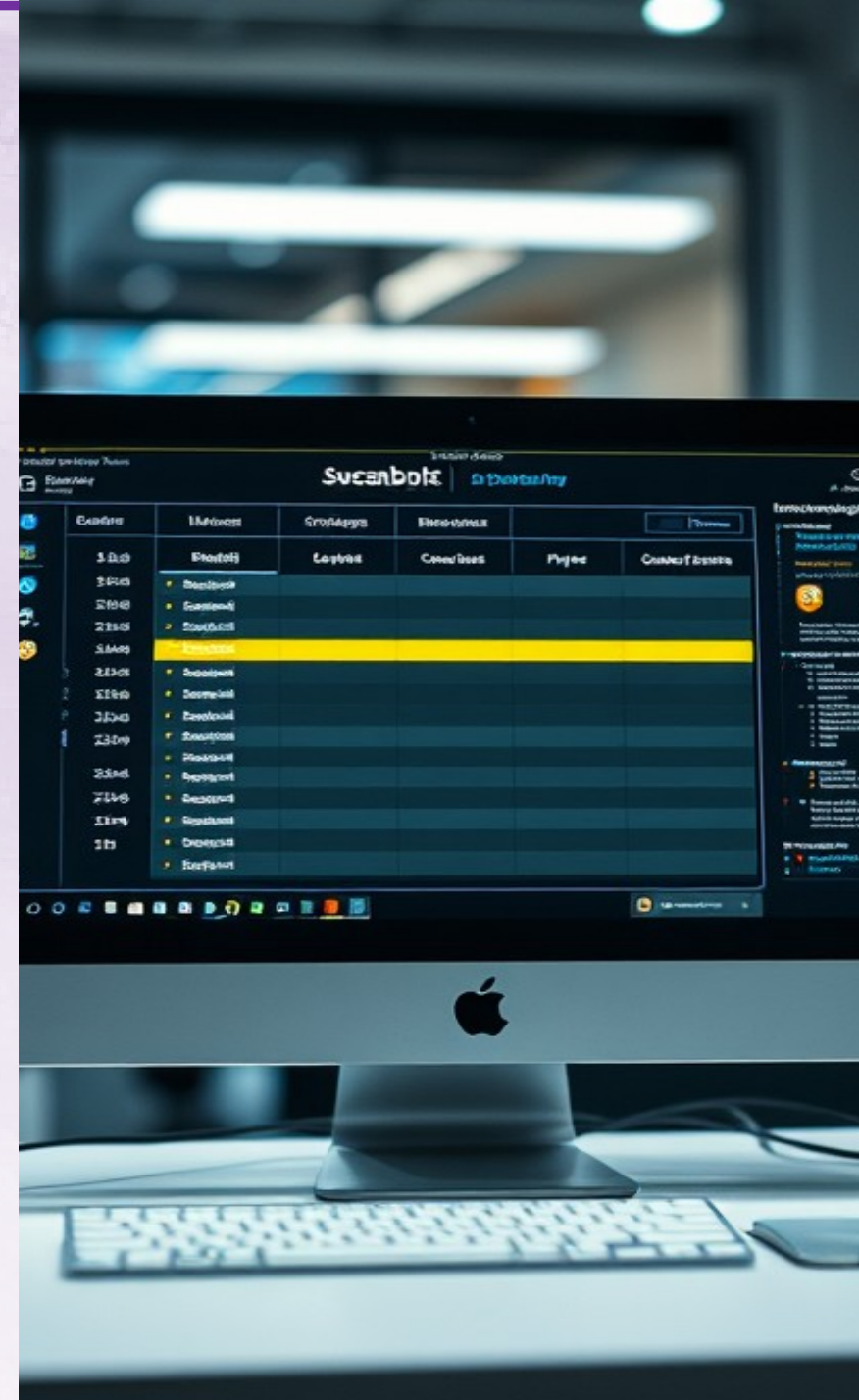
- Adds multiple assurance layers for sensitive areas

Update policies for incidents like lost badges or staff changes

- Rapid revocation and regular reviews protect access

Control effectiveness depends on technology and policy rigor

- Integration of practices ensures robust protection





Real-World Lessons from Offboarding Risks

Data breaches can result from delayed removal of credentials

- Terminated staff may exploit lingering access

Physical controls must be responsive and dynamic

- Stale credentials present critical security gaps

Integrating physical controls with wider security operations is key

- Network defenses alone are not enough

Timely offboarding is vital for preventing physical breaches

- Regular updates prevent unauthorized entry

Self-Assessment for Physical Security

Reflect on locations where cardholder data is stored or processed

- Identify all sensitive storage and processing points

Examine barriers between public and sensitive areas

- Assess weakness of existing physical controls

Seek ways to enhance physical access barriers or verification

- Consider new layers or stronger controls

Self-assessment is the first step for meaningful improvement

- Drives continuous security enhancement



Media Handling Risks and Exposures

Media covers all physical storage of cardholder data

- Includes tapes, reports, USB drives, and hard drives

Risks include unauthorized access and data removal during handling

- Media can "walk out the door" unnoticed

Unsecured printed reports or unsupervised access jeopardize data

- Lack of logging allows undetected removal

Backup tapes require encryption, logging, and trusted transfer

- Mishandling exposes thousands of records



Implementing Secure Media Handling Procedures

Media must be labeled and stored in restricted locations

- Restricts unauthorized access to data assets

Encrypt data prior to transport or disposal

- Secures media even if lost or stolen

Maintain detailed chain-of-custody records for all media movements

- Supports audits and tracks accountability

Periodically check inventory to detect missing media

- Reconciles physical items with documented lists





Benefits of Regular Inventory Checks

Designated staff reconcile inventory with documented media lists

- Discrepancies trigger immediate investigation

Regular checks deter theft and misplacement

- Accountability is reinforced by documentation

Inventory checks protect organizations from undetected data loss

- Prompt action limits risk exposure

Documented checks proactively strengthen media security culture

- Overhauls often follow close calls or audits

Visitor Management Policies and Risks

Visitors represent unique risks to cardholder data

- May access or observe sensitive information

All visitors should sign in and present identification

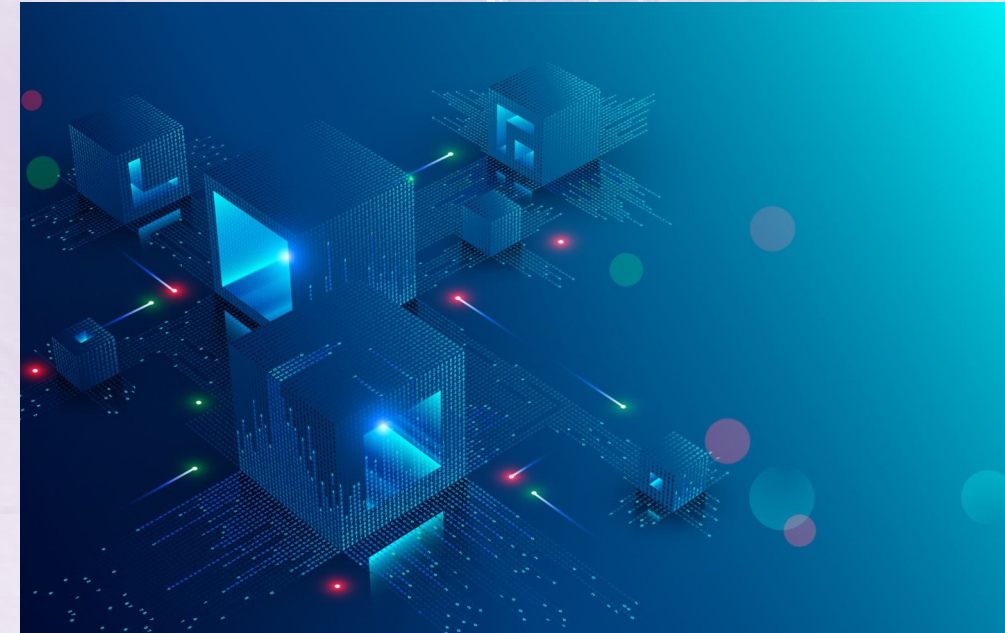
- Temporary badges distinguish visitors from staff

Escort visitors at all times in restricted areas

- Record entry and exit for auditing

Regular reviews may reveal unmonitored access risks

- Policy enforcement is essential



Enhancing Visitor Security with Technology and Culture

Video surveillance documents movements and supports investigations

- Visual records strengthen oversight

Electronic visitor logs provide valuable audit trails

- Data supports post-incident review

Staff vigilance is critical for effective security

- Employees are empowered to challenge unfamiliar faces

A culture of reporting and awareness improves overall defense

- Mobilizes all staff as security guardians



Organizational Impact of Physical Security

Physical security protects data and fosters customer trust

- Reassures business partners and regulators

Lapses cause reputational damage, financial loss, and legal issues

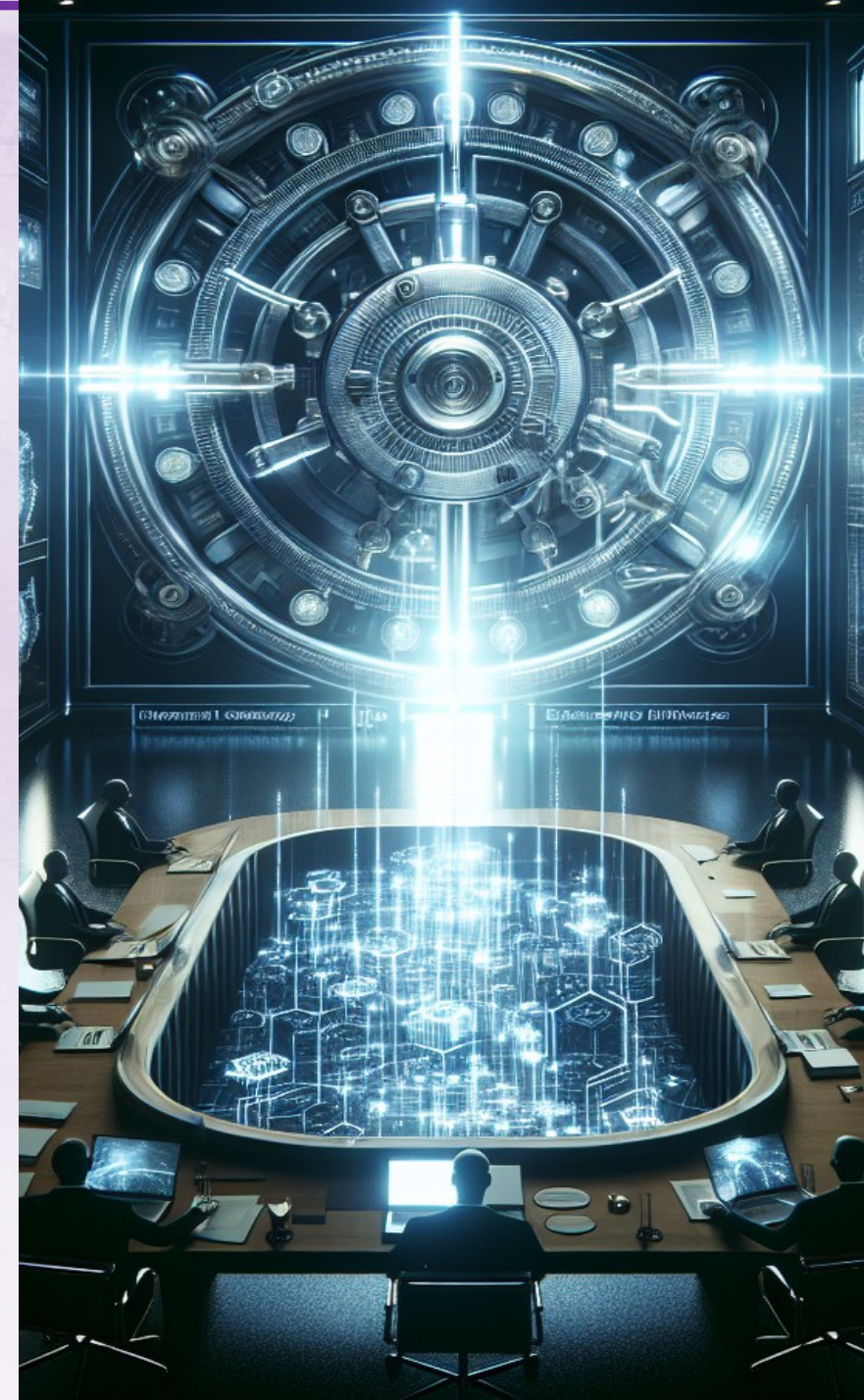
- Real incidents led to fines and backlash

Unencrypted data in unsecured locations increases breach risk

- Example: stolen drives from unlocked closets

Robust controls demonstrate serious responsibility to all stakeholders

- Evidence of compliance and care





Comparing Physical Security Approaches

Some organizations invest in advanced security technologies

- Biometrics, motion detectors, and continuous surveillance

Others implement strict procedural controls and staff patrols

- Keys, visitor sign-in, and regular patrols

Blending both creates overlapping and resilient security layers

- Compensates for weak points in any single method

Vigilant staff provide a safety net when technology fails

- Manual logs and alerts supplement systems

Applying Security Principles to Real Scenarios

Match controls to facility layout and data sensitivity

- Choices inform risk-based decisions for each area

Badge systems, biometrics, cameras, and mantraps are options

- Select based on access needs and breach impact

Media handling improves with enhanced controls like inventory checks

- Detects early loss and fosters vigilance

Control selection must fit data sensitivity and organization needs

- Align measures with access volume and risk



Challenges in Maintaining Physical Security Controls

Physical environments change and may introduce security gaps

- Renovations, turnover, and new tech affect controls

"Set and forget" mentality weakens safeguards over time

- Infrequent reviews lower effectiveness

Mitigate risks using scheduled reviews and ongoing training

- Adapt controls as threats evolve

Continuous improvement is needed for lasting protection

- Regular updates sustain security strength



Foundations for a Culture of Security Excellence

Physical security controls prevent breaches beyond digital measures

- Safeguards data where digital defenses cannot

Media handling, facility controls, and visitor management are essential

- Practical, real-world scenarios reinforce their value

Effective programs reflect human vigilance and continuous reflection

- Organizational culture underpins security effectiveness

Enhancing physical controls is an opportunity for trust and resilience

- Contributes to professional growth and accountability

